

Security & De-identification

What seventeen papers told us about protecting a trading book from a cloud model — and what they told us we had already got wrong.

Research summary Yudi Guo 20 Sept 2026

We were aiming at the wrong target

“Exit the regional-bank book before the Fed meeting.”

No name, no account number, no identifier of any kind — and the whole strategy is disclosed.

SENSITIVE IS NOT THE SAME AS PERSONAL

Our diagrams said “PII detection.” What this desk needs protected is **intent** — the watchlist, the entry rules, the positions. A personal-data detector scores perfectly on that sentence and catches nothing in it.

4%

of the content a task needed survived a filter that scored sensitivity alone. Adding a second judgement — does this question actually require it — recovered 95%.

MINIM · ICML 2026

A SINGLE ON/OFF GATE BREAKS THE ASSISTANT

One sensitivity threshold is what we had drawn. It would have stripped out almost everything the assistant answers with, and still leaked twice as much as the two-judgement version.

Three pitfalls in how we planned to measure

9%

of medical records were still re-identified after a tool had masked every identifier it could find.

DIRI · arXiv:2410.17035

DETECTION SCORES ARE NOT PRIVACY SCORES

We were going to report detection accuracy as evidence the gateway was safe. It measures the detector, not the outcome. A separate benchmark makes the same point about the specific tool we intend to use.

48%

is how often eighty human reviewers agreed with each other on context-dependent sensitivity. On explicit identifiers they agreed 90% of the time.

RedactionBench · arXiv:2606.18782

SOME OF THIS CANNOT BE SCORED AT ALL

No judgement of “is this contextually sensitive” can be validated much past that figure — ours included. We set it by written policy instead of judging case by case, and report the ceiling rather than a number implying more precision than exists.

+12

points more leakage once a conversation was allowed to continue for two follow-up questions, compared with scoring the first message alone.

Information Sufficiency · arXiv:2604.06409

TESTING ONE QUESTION AT A TIME FLATTERS THE RESULT

Our assistant is conversational. Any evaluation that scores a single request will overstate how safe it is, so leakage has to be measured across a whole working session.

How the system decides what is sensitive

This was the question raised in the September review, and the 48% figure above is the reason for the shape of the answer: **most of it is not judged at all**. Four layers, and only the last one involves an opinion.

BASIS

COVERS

CAN IT BE WRONG?

Where it came from	The position store is confidential by construction; a filing pulled from EDGAR is public by construction. No inspection of the content is needed.	No — the label is assigned, not inferred. This carries most of the load.
Pattern	Securities identifiers carry check digits; account numbers have fixed formats.	No — it either passes the checksum or it does not.
Written policy	A table saying what each kind of thing counts as: a ticker drawn from the book reveals attention; a quantity reveals the book itself.	No — it is a decision, not a measurement. One page, and yours to review.
Judgement	Free-text notes the trader wrote themselves.	Yes — and this is where the 48% ceiling applies, so we do not try. Notes are dropped by default rather than scored.

Sensitivity is only half of it. The second judgement is whether *this particular question* needs the field at all — and that is fixed by the kind of question being asked, not by the content. A question about concentration risk needs the weights but never the names, so the names are removed regardless of how sensitive anyone thinks they are. Uncertainty on one axis is absorbed by certainty on the other.

- **Partial restriction** — each field gets its own treatment rather than the whole prompt being allowed or blocked. See the table in the next section.
- **Output censorship** — the return path is checked as well as the outbound one; the cloud’s reply is treated as untrusted input.
- **Split routing** — the public half of a question goes to the cloud while the confidential half is answered locally, and the two are merged on the device.

Three alternatives to a strict binary gate were proposed in that review. All three are in the design above.

Three ways to disguise sensitive data

The literature offers three. We measured them against our own situation rather than taking the most cited.

STRATEGY	WHAT IT DOES	WHAT THE EVIDENCE SAYS
Suppress	Delete it	Safest and costliest. Gaps in an answer invite follow-up questions, which create fresh chances to leak.
Generalise	Say something broader but still true	The strategy that degrades most under follow-up. One study found it performs <i>worse than no protection at all</i> on the combined measure.
Substitute	Replace with a plausible alternative	Best overall in the study that proposed it — but that study explicitly excludes recipients who need the true value, and our cloud model computes with it.

Neither recommendation transfers cleanly, because our assistant is **both** conversational (so generalising degrades) and **computational** (so a false substitute corrupts the arithmetic). Swapping one regional-bank ETF for another changes the sector mix and rate sensitivity the cloud is reasoning about, and the answer comes back quietly wrong. What we propose splits the decision by field type:

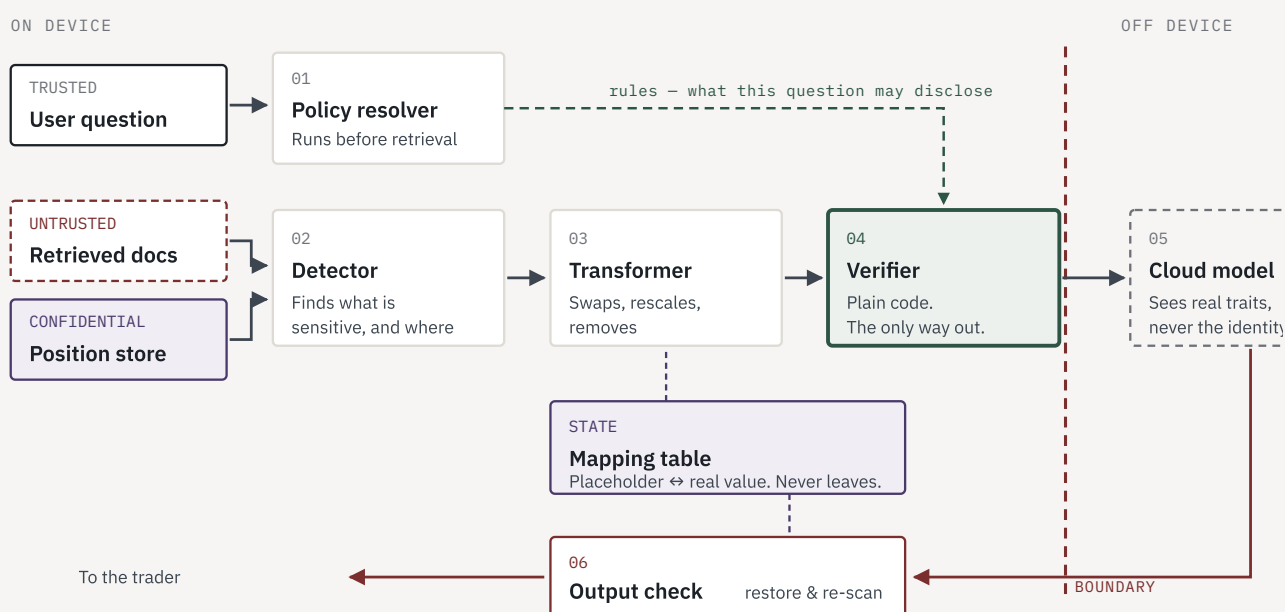
Only the first two can be reversed when the answer comes back.

FIELD	TREATMENT	WHY
-------	-----------	-----

FIELD	TREATMENT	WHY
Instrument	KRE → Instrument A plus its true characteristics	The cloud reasons on real sector, duration and rate sensitivity without learning which holding it is looking at.
Quantity	Rescaled by a secret factor	Concentration questions depend on ratios, not absolute size. We disclose the shape of the book, never its scale.
Attribute	Broadened, but kept true	A vaguer statement is still a correct one. A false one is not.
Strategy note	Dropped entirely	Highest value to an adversary, and rarely needed to answer the question.

What this implies for the design

Three conclusions carry over from the reading. The shape below is what they produce when put together; the detail is in the full review.



- Whatever decides what leaves must be code, not a model.** In one trial an independent authorisation layer left the model fooled *every single time* and zero unsafe actions executed. A model can be argued into anything by text it reads; a deterministic check cannot. IEEE CARS 2026
- Decide before retrieving.** Our original flow let the model read retrieved filings and *then* choose what could leave — so anyone who plants text in a filing controls that choice. Fixing the rules from the question first is a reordering, not new machinery.

- 3 **Budget the whole session.** Twenty individually harmless questions can still reveal the book, and nothing that inspects one request at a time will notice. The same idea as a privacy budget, applied to a conversation.

How we will prove it works

Five separate measurements. Collapsing them into one “accuracy” figure is the most common mistake in this area, and it hides exactly the failures that matter.

QUESTION	MEASURE	WHY THIS ONE
Does it catch things?	Detection rate per category, weighted toward misses	A miss is a permanent disclosure; a false alarm is a slightly worse answer.
Does anything escape?	Leak rate at the network boundary	We plant invented secrets locally and watch every outgoing byte. Catches what detector scores cannot: logs, traces, error paths.
What does privacy cost?	Answer quality with protection on versus off	The figure that tells you what you are paying for this.
Does it survive attack?	Attack success and unsafe actions, counted separately	The two diverge, as the trial above shows.
Does it hold over time?	Disclosure measured across a whole session	Single-question testing systematically understates how much escapes.

Open resources

Four public artifacts cover work we would otherwise repeat. None was built for finance, which is why the extensions are ours.

SOURCE	WHAT IT GIVES US	STATUS
llm-redactor	A working shim between an agent and a cloud endpoint, plus a labelled leak benchmark of 1,300 samples — the evaluation set we currently lack.	Verified public
Presidio	The detection engine itself, with reversible substitution already built in. We add the financial identifiers it has no notion of.	Verified public

SOURCE	WHAT IT GIVES US	STATUS
MINIM	Reference implementation of the two-judgement policy behind the 4% finding.	Verified public
RedactionBench	200 annotated documents and a matching metric, including the human-agreement study behind the 48% figure.	Announced, unconfirmed

Open questions

None of this was tested on financial data. Every method we reviewed was validated on medical, legal or social text. Our domain, where the secret is direction and exposure rather than identity, is untested ground.

Published results mostly measure personal data, and ours is not that. One study ran the same protections across content types: personal data leaked 0.6% of the time, proprietary content 31%. A trading rule has no names in it — structurally it is the second kind.

Our field-by-field scheme is a proposal, not a result. We will run it against the two established alternatives rather than assume it wins.

How much one session may disclose in total is a business decision. We can measure how quickly an observer closes in on the book; where to draw the line is a question for you.

The architecture is not novel and we do not claim it is — two 2026 papers describe the same local-to-cloud pattern, and the enforcement design applies a fifty-year-old security principle to a language-model egress path. What is new is the financial-domain handling and the measurement.